

Matriz de Evaluación PRAGMATIC Completa

Escala: 0 = No cumple, 1 = Bajo, 2 = Medio, 3 = Alto.

PRAGMATIC: P (Predictivo), R (Relevante), A (Accionable), G (Genuino),
M (Significativo), P2 (Preciso), T (Oportuno), I (Independiente), C (Rentable).

Tabla resumen de métricas clave

ID	Métrica	Objetivo GQM	P	R	A	G	M	P2	T	I	C	Comentario sintético
M1.1	Nº de brechas notificadas/año	G1	1	3	2	3	3	3	3	3	2	Muy relevante para G1, descriptiva más que predictiva.
M1.2	Nº total de incidentes con impacto en datos personales	G1, G3	2	3	3	2	3	2	2	2	2	Mejora visión global, algo costosa de medir con precisión.
M1.3	% de brechas mitigadas por medidas técnicas	G1, G2	2	3	3	2	3	2	2	2	2	Conecta calidad de controles con impacto real.

M1.4	Importe total de sanciones RGP D/año (seguridad)	G1	1	3	2	3	3	3	3	3	2	Potente como indicador de resultado y presión externa.
M1.5	Nº de reclamaciones sobre seguridad del tratamiento	G1	1	3	2	2	3	2	3	3	3	Buena alerta temprana de problemas de percepción/realidad.
M2.1	% de datos en reposo cifrados	G2	2	3	3	2	3	2	2	3	2	Métrica estructural clave, relativamente barata de obtener.

M2.2	% de datos en tránsito cifrados	G2	2	3	3	2	3	2	2	3	2	Similar a M2.1, imprescindible en cuadros de mando técnicos.
M2.3	% de sistemas con MFA	G2	2	3	3	2	3	2	2	3	2	Directamente accionable (lista clara de sistemas pendientes).
M2.4	Tiempo medio de parcheo de vulnerabilidades críticas	G2, G3	3	3	3	2	3	2	2	3	2	Altamente predictiva del riesgo de explotación.

M2.5	% de trata mien tos con análi sis de riesg os/EI PD actua lizad os	G2, G5	2	3	3	2	3	2	2	3	2	Mide profu ndid ad del enfo que basa do en el riesg o.
M2.6	Nivel de mad urez ISO 2700 1/277 01 o NIS2	G2, G5	2	3	2	2	3	2	1	2	1	Útil pero más subje tiva; convi ene comp leme ntarl a.
M3.1	MTT R-detec ción de incid entes	G3	3	3	3	2	3	2	2	3	2	Núcl eo de capa cidad SOC; muy accio nable .
M3.2	MTT R-resp uesta / conte nción	G3	3	3	3	2	3	2	2	3	2	Com plem enta a M3.1 y orien ta inver sione s en resp uesta .

M3.3	% de brechas notificadas < 72 h	G3, G1	2	3	2	3	3	3	3	3	3	Directamente ligado a cumplimiento RGP D art. 33.
M3.4	Nº de simulacros de incidentes /año	G3, G5	2	3	3	3	3	3	2	3	3	Bajo coste, alto valor cultural y operativo.
M3.5	Nº medio de acciones de mejora tras incidentes	G3, G5	2	3	3	2	3	2	2	3	3	Conecta incidentes con aprendizaje organizativo.
M4.1	% de proveedores evaluados	G4	2	3	3	2	3	2	2	3	2	Clave para cadena de suministro; requiere buena inventariación.

M4.2	% de proveedores críticos certificados	G4	2	3	3	2	3	2	2	3	2	Facilita priorización de remediación y negociación contractual.
M4.3	Nº de incidentes originados en terceros	G4, G1	2	3	2	2	3	2	2	3	3	Métrica de resultado centrada en cadena de suministro.
M4.4	% de proveedores monitoreados continuamente	G4	2	3	3	2	3	2	2	3	1	Aporta visibilidad continua, pero herramientas pueden ser costosas.

M5.1	Existencia y actualización de cuadro de mando	G5	1	3	3	3	3	3	3	3	3	Métrica binaria pero esencial para gobernanza basada en datos.
M5.2	IGM global	G5	2	3	3	2	3	2	2	2	2	Gran capacidad de síntesis; requiere interpretar sus componentes.
M5.3	Nº de reportes anuales al consejo	G5	1	3	2	3	3	3	3	3	3	Refuerza accountability y supervisión.

M5.4	% de empl eado s con form ación actua lizad a	G5, G2	2	3	3	2	3	2	2	3	2	Indic ador cultu ral clave, fácil de medi r por RR. HH.
M5.5	ROI estim ado de inicia tivas clave de cum plimi ento	G5	2	3	3	2	3	1	1	3	1	Pote nte para decis ión de inver sión, pero depe nde de supu estos.

Comentarios adicionales por criterio

- Métricas como M3.1 y M3.2 puntúan alto en Predictivo y Accionable: reducciones en MTTR se correlacionan con reducción de impacto de incidentes y orientan la inversión en capacidades de detección y respuesta. [web:25][web:22]
- M1.4 (sanciones anuales) es muy significativa y relevante, pero poco predictiva por sí sola; refleja más bien la “factura” de años previos que una predicción precisa de futuro. [web:3][web:6][web:11]
- M5.5 (ROI) es conceptualmente muy potente, pero su precisión depende de la calidad de estimaciones de probabilidad e impacto; se recomienda usarla como indicador de orden de magnitud, no de exactitud contable. [web:12]
- Métricas redundantes o poco independientes deberían ser consolidadas (p. ej. M2.1 y M2.2 pueden combinarse en un índice de “cobertura de cifrado”).

Esta matriz puede extenderse con métricas adicionales específicas de sector (salud, finanzas, energía) manteniendo la misma lógica de evaluación.